



Coinbase NitroEnclaveVeri- fier

Security Review

Cantina Managed review by:
Zigtur, Lead Security Researcher
Akshay Srivastav, Security Researcher

April 16, 2026

Contents

1	Introduction	2
1.1	About Cantina	2
1.2	Disclaimer	2
1.3	Risk assessment	2
1.3.1	Severity Classification	2
2	Security Review Summary	3
2.1	Scope	3
3	Findings	4
3.1	Informational	4
3.1.1	Attestation can be valid up to 1 hour after certificate expiration	4
3.1.2	Revoking an intermediate certificate does not revoke child certificates	4
3.1.3	Outdated comments	5
3.1.4	checkTrustedIntermediateCerts may revert with unexpected error	5
3.1.5	Revoked certificates can be trusted again	5

1 Introduction

1.1 About Cantina

Cantina is a security services marketplace that connects top security researchers and solutions with clients. Learn more at cantina.xyz

1.2 Disclaimer

Cantina Managed provides a detailed evaluation of the security posture of the code at a particular moment based on the information available at the time of the review. While Cantina Managed endeavors to identify and disclose all potential security issues, it cannot guarantee that every vulnerability will be detected or that the code will be entirely secure against all possible attacks. The assessment is conducted based on the specific commit and version of the code provided. Any subsequent modifications to the code may introduce new vulnerabilities that were absent during the initial review. Therefore, any changes made to the code require a new security review to ensure that the code remains secure. Please be advised that the Cantina Managed security review is not a replacement for continuous security measures such as penetration testing, vulnerability scanning, and regular code reviews.

1.3 Risk assessment

Severity level	Impact: High	Impact: Medium	Impact: Low
Likelihood: high	Critical	High	Medium
Likelihood: medium	High	Medium	Low
Likelihood: low	Medium	Low	Low

1.3.1 Severity Classification

The severity of security issues found during the security review is categorized based on the above table. Critical findings have a high likelihood of being exploited and must be addressed immediately. High findings are almost certain to occur, easy to perform, or not easy but highly incentivized thus must be fixed as soon as possible.

Medium findings are conditionally possible or incentivized but are still relatively likely to occur and should be addressed. Low findings are a rare combination of circumstances to exploit, or offer little to no incentive to exploit but are recommended to be addressed.

Lastly, some findings might represent objective improvements that should be addressed but do not impact the project's overall security (Gas and Informational findings).

2 Security Review Summary

Base is a secure, low-cost, builder-friendly Ethereum L2 built to bring the next billion users onchain.

From Apr 10th the Cantina team conducted a review of [contracts](#) on commit hash [ffe2af8c](#). The team identified a total of **5** issues:

Issues Found

Severity	Count	Fixed	Acknowledged
Critical Risk	0	0	0
High Risk	0	0	0
Medium Risk	0	0	0
Low Risk	0	0	0
Gas Optimizations	0	0	0
Informational	5	3	2
Total	5	3	2

2.1 Scope

The security review had the following components in scope for [contracts](#) on commit hash [ffe2af8c](#):

```
src/multiproof/tee/NitroEnclaveVerifier.sol
```

3 Findings

3.1 Informational

3.1.1 Attestation can be valid up to 1 hour after certificate expiration

Severity: Informational

Context: NitroEnclaveVerifier.sol#L616-L627

Description: The ZK prover verifies that the certificate chain is valid at the attestation timestamp (`doc.timestamp / 1000`). `TEEProverRegistry` then allows attestations up to `MAX_AGE = 60` minutes old. This means a certificate that expires at time `T` can still produce valid attestations until `T + 60` minutes, because:

1. An attestation generated at time `T - 1` (just before expiry) has a valid cert chain.
2. This attestation can be submitted to the contract up to `T + 59min59s`.

In practice, this is acceptable since certificate private keys are unlikely to be compromised within 1 hour of expiration.

Note: This issue was reported in a previous audit and was fixed by documenting the edge-case. However, the new `journal.certExpiries` field allows the NitroEnclaveVerifier to now check all the certificate timestamps to ensure that they are still valid.

Recommendation: Consider ensuring that `block.timestamp` is lower than or equal to certificate timestamps in `journal.certExpiries` for all not-yet-trusted certificates. This can be implemented in `_verifyJournal` with the following patch.

```
diff --git a/src/multiproof/tee/NitroEnclaveVerifier.sol
    ↪ b/src/multiproof/tee/NitroEnclaveVerifier.sol
index 0a624380..684012ce 100644
- -- a/src/multiproof/tee/NitroEnclaveVerifier.sol
+ ++ b/src/multiproof/tee/NitroEnclaveVerifier.sol
@@ -619,6 +619,14 @@ contract NitroEnclaveVerifier is Ownable, INitroEnclaveVerifier,
    ↪ ISemver {
        return journal;
    }
}
+ // Check any remaining certificates in the chain that are not yet trusted
+ for (uint256 i = journal.trustedCertsPrefixLen; i < journal.certs.length; i++)
    ↪ {
+     uint64 expiry = journal.certExpiries[i];
+     if (block.timestamp > expiry) {
+         journal.result = VerificationResult.InvalidTimestamp;
+         return journal;
+     }
+ }
    uint64 timestamp = journal.timestamp / 1000;
    if (timestamp + maxTimeDiff <= block.timestamp || timestamp >=
        ↪ block.timestamp) {
        journal.result = VerificationResult.InvalidTimestamp;
```

Coinbase: Fixed in PR 251.

Cantina Managed: Fixed. The patch has been applied.

3.1.2 Revoking an intermediate certificate does not revoke child certificates

Severity: Informational

Context: NitroEnclaveVerifier.sol#L348-L354

Description: The `revokeCert()` function allows the revoker and the owner to revoke a specific `certHash` by deleting it from the `trustedIntermediateCerts` mapping.

However, this function does not allow revoking the child certificates that depend on the `certHash` being revoked. This may lead to inconsistencies where child certificates are still marked as trusted.

Note: This has no impact thanks to the `rootCert` check in `_verifyJournal`. An untrusted intermediate certificate will require all its child certificates to go through a new certificate verification.

Recommendation: Revoking child certificates could be handled by tracking the certificate path dependency on-chain. Alternatively, this can be handled off-chain by the revoker.

Coinbase: Acknowledged.

Cantina Managed: Acknowledged.

3.1.3 Outdated comments

Severity: Informational

Context: `INitroEnclaveVerifier.sol#L28-L30`, `INitroEnclaveVerifier.sol#L141`, `NitroEnclaveVerifier.sol#L323-L324`

Description: The codebase shows multiple outdated comments:

- `INitroEnclaveVerifier.sol#L28-L29`: *"Note: This struct stores the "latest" (active) program identifiers. Multiple versions can be supported simultaneously via the version management functions."*
- `INitroEnclaveVerifier.sol#L141`: *"Multi-version program support for seamless upgrades"*.
- `NitroEnclaveVerifier.sol#L323`: *"Note: Program IDs are automatically added to the supported version sets"*.

These comments are not valid anymore as recent changes removed the support of multiple program identifiers. Now, a single configuration is accepted instead of a set of configurations.

Recommendation: Modify the comments to match the new behavior of the codebase.

Coinbase: Fixed in [PR 251](#).

Cantina Managed: Fixed. The comments have been removed.

3.1.4 `checkTrustedIntermediateCerts` may revert with unexpected error

Severity: Informational

Context: `NitroEnclaveVerifier.sol#L264-L266`

Description: The `checkTrustedIntermediateCerts` function may revert with an `Index out of bounds` error when the input `certs` length is zero. This is because the code expects at least one element by reading `certs[0]`.

Recommendation: While the code is not vulnerable, reverting with a dedicated error on zero length can be better for debugging.

Coinbase: Acknowledged.

Cantina Managed: Acknowledged.

3.1.5 Revoked certificates can be trusted again

Severity: Informational

Context: `NitroEnclaveVerifier.sol#L337-L347`

Description: The new `revokeCert` functionality allows the revoker and the owner to revoke specific certificates. The natspec comments specifically indicate the following.

```

/**
 * @dev Revokes a trusted intermediate certificate
 * @param certHash Hash of the certificate to revoke
 *
 * Requirements:
 * - Only callable by contract owner or revoker
 * - Certificate must exist in the trusted intermediate certificates set
 *
 * This function allows the owner or revoker to revoke compromised intermediate
 * ↪ certificates
 * without affecting the root certificate or other trusted certificates.
 */

```

However, this revocation mechanism is not a "blocklist". This means that a compromised intermediate certificate can be revoked through `revokeCert` and then marked as trusted again through a ZK proof verification.

This is mainly due to the fact the Certification Revocation Lists (CRL) are not supported by the zkVM program.

Recommendation: Trusted certificates can only be added by a trusted party, this reduces the impact of this issue. Consider adding comments to mention the fact that revoked certificates can be trusted again.

Coinbase: Fixed in [PR 251](#).

Cantina Managed: Fixed. The edge-case has been documented.